

INSTRUCTOR-LED COURSE • REVISION MATERIAL

SC-500

Cloud and AI

Security Engineer

Condensed revision notes covering all fifteen modules, with cross-module comparison tables for the distinctions most often confused under exam conditions.

Prepared by Yash Mudaliar

Edition 1.0 • August 2026

Scope Modules 1.1 to 4.5, delivered across four days

Technical currency Product behaviour, limits and licence boundaries checked against Microsoft Learn at the date above

How to use these notes

One page of orientation, then the course itself, then the comparison tables that carry most of the value.

MARKER	MEANING
KEY	High-yield. Flagged as examinable in the deck or in delivery. If you have twenty minutes, read only these.
TRAP	Behaves against expectation, or is commonly answered wrongly by people who sat the whole course.
→	Scenario cue. The wording on the left points at the component on the right.

PAGES	CONTENTS
3–11	The fifteen modules, in delivery order, two columns per page
12–14	Cross-module comparison tables. The distinctions that get confused precisely because they were taught in different modules. The highest-yield pages here
15	Night-before page: the claims that sound right and are wrong

The pattern behind most scenario questions. Almost every SC-500 question describes a required *outcome* and asks which component delivers it. So what pays is knowing which capability belongs to which service, plan and layer, rather than the configuration steps. Three questions resolve most of them: **which plane** (identity, management or data), **which layer** (prevent, detect or govern), and **which tier** (free or paid, P1 or P2, Plan 1 or Plan 2).

THE COURSE AT A GLANCE

DAY	MODULES	THEME
One	1.1 Identity Governance · 1.2 Key Vault · 1.3 Governance and Role Management	Who may do what, for how long, and to which resources
Two	2.1 Storage · 2.2 Databases · 2.3 Networking	Protecting the data plane and the path to it
Three	3.1 Purview DSPM · 3.2 Agent Identity · 3.3 Foundry and AI Gateway · 3.4 AI Security Monitoring	AI workloads: exposure, identity, endpoint, verification
Four	4.1 Servers · 4.2 Application Platform · 4.3 Defender CSPM · 4.4 Sentinel · 4.5 Security Copilot	Workload protection, posture and operations

Three ideas that recur in every module.

- **Control plane against data plane.** Management operations and data operations are governed separately, and a control on one does not cover the other. Storage, SQL, Key Vault and CSPM secret scanning all turn on this.
- **Identify, enforce, detect.** Every product in the course sits in one of the three. DSPM identifies, Information Protection enforces, Defender detects. Confusing them is the most common wrong answer.
- **Configured is not working.** A connector status, a saved policy, an assigned plan and an applied label all report success without proving effect. Verification is a separate step, and the exam knows it.

1.1 Identity Governance and Access Control

PIM · CONDITIONAL ACCESS · ID PROTECTION

The idea: access that exists continuously is available continuously, to whoever obtains the credential. Standing access is the attack surface; just-in-time is the response. Activation does not reduce *what* a principal can do, it reduces how long that is true, how deliberate it had to be, and how visible it is.

KEY **PIM role states.** **Permanent:** legacy pattern, retained only for emergency access (break-glass) accounts. **Eligible:** the target state; the principal holds a pre-authorised *path*, not the permission. **Active:** the time-bounded result of an activation, expiring on its own.

KEY **Activation workflow, and the property each step delivers:** request → policy evaluation → active window → automatic expiry. Justification produces *accountability*; MFA produces *identity verification at the moment of elevation*; approval introduces *human oversight*; the audit log produces the *evidence* that standing access never generated.

Entra Agent IDs are governed the same way, not similarly. They take PIM eligible assignments, can be governed through access packages, and carry a **sponsor**: a named human accountable for that agent's lifecycle and access. **Blueprints** are templates describing a type of agent; individual agent identities are created from them, parent to child. Lifecycle is creation → role assignment → **decommissioning**. **TRAP** Decommissioning is where the model fails: humans have a leaver process because HR generates one; agents have none unless somebody builds it.

Managed identity removes the stored credential rather than protecting it. This is the pattern that recurs through the whole course.

Access controls. Security defaults are a *floor*; Conditional Access is the *precision instrument*. Microsoft's mandatory MFA enforcement for Azure administration sits beneath both and applies whether or not you configured it. A CA policy is **assignments + conditions + access controls**, and it is deployed in **report-only mode** first.

KEY **TRAP** **Sign-in risk vs user risk:** routinely conflated. **Sign-in risk** concerns *this authentication attempt* and calls for verification of the person, so the remediation is MFA. **User risk** is *cumulative across events* and expresses the probability the account itself is compromised, so the remediation is a **secure password reset**, not a prompt.

Entra ID Protection detections split two ways. *Heuristic and behavioural:* impossible travel, atypical location, first sign-in from a new country, unfamiliar sign-in properties. These compare against a learned baseline. *Evidential:* **leaked credentials** (matched against a breach corpus) and **verified threat actor address**. These are not probabilistic and are always treated as **high**. A medium heuristic detection warrants an extra check; a high evidential detection warrants blocking and human review.

Risk tiers are **low, medium, high**, produced by machine learning. **TRAP**

Licensing: full detail on most risk detections requires **Entra ID P2**. Without it, premium detections surface only as a generic indication that additional risk was detected — enough to know something happened, not enough to investigate.

Policy stated as one sentence (the form to aim for): for all users and all cloud apps, when sign-in risk is medium or higher require multifactor authentication, and when it is high, block.

1.2 Securing Azure Key Vault

MANAGED IDENTITY FLOW · NETWORK · DELETION PROTECTION

The vault is the authoritative boundary for secrets, keys and certificates, the single location for that material. A vault holding a copy of a credential that also sits in application settings has not established a boundary; it has added a location.

Access = RBAC + managed identity, and the two depend on each other. RBAC without managed identity gives precise scoping of an identity that is itself authenticated by a password. Managed identity without scoped roles gives a credential-free workload that can read everything.

KEY **The managed identity token flow, examined in detail, not in outline.**

Precondition: a managed identity assigned to the workload. A *system-assigned* identity shares the lifecycle of its resource (cleanest for a single workload); a *user-assigned* identity survives independently.

- 1. Token request.** The workload asks a local metadata endpoint — on a VM, the Instance Metadata Service at a link-local, non-routable address reachable only from inside the resource.
- 2. Token issued.** Entra returns an access token valid for roughly a day, cached at the metadata layer. SDKs handle caching and refresh, so a token is not requested on every call.
- 3. Call the vault.** The token is presented as a **bearer token**: possession is treated as authority, which is why it is short-lived and why TLS is required.
- 4. Vault validates.** It checks the token, resolves the calling identity, confirms that identity holds a role permitting the operation *at the requested scope*, and returns the secret. The operation is written to the audit log.

TRAP **The silent failure.** This flow can be implemented correctly and still leave a stored credential in place, because the application **falls back to a connection string** when the token request fails. The fallback is usually there for local development and nobody removes it.

Network access, three postures, increasing restriction: public endpoint with a firewall allow-list → service endpoint from named subnets → private endpoint.

TRAP **The trusted Microsoft services bypass** admits services such as Backup and Event Grid *regardless of the firewall*, so it is a deliberate trust decision rather than a default to leave alone.

KEY **Deletion protection, both are provisioning-time decisions because neither can be undone later.** **Soft delete** is now mandatory, with a retention window of **7 to 90 days** fixed at creation. **Purge protection** is opt-in and, once enabled, **cannot be turned off**; within the retention window it prevents permanent destruction by any principal, including a Global Administrator, and including Microsoft.

Scope is a security control, not an administrative detail. A storage account key grants access to the entire account rather than a single container, so one discovered credential opens more than the workload it was created for.

Defender for Key Vault with attack path analysis provides detection on the assumption that prevention will eventually fail. It asks the question no preventive control asks: *is this authorised activity behaving normally?* Every step of a credential-theft chain uses a valid credential and produces a successful authentication, so without behavioural detection the whole incident looks like ordinary traffic.

1.3 Security Governance and Role Management

AZURE POLICY · RBAC · LOCKS

KEY **Two mechanisms solving two halves of one problem.** Azure Policy controls what resources are *allowed to be*. RBAC controls what principals are *allowed to do*.

Policy structure: definitions → initiatives → assignments → scope.

Effects: **Audit** measures · **Deny** keeps new drift out · **DeployIfNotExists** clears drift that is already there. **TRAP** The common failure is stopping at Audit and calling it governance.

DeployIfNotExists remediation deploys the missing configuration through the **assignment's managed identity**. Enforcing a new baseline against an estate that predates it is an *active remediation operation*: it does not happen on its own and it does not arrive gradually. Two phases with different risk: the assignment is cheap, fast and reversible; the remediation run changes live resources at scale and needs a change window, a rollback position and somebody watching.

RBAC assignment = principal + role definition + scope, inheriting down the hierarchy. **TRAP** Of the three, **scope carries the error most often and gets examined least**. **Contributor** is the clearest over-grant: it permits managing

essentially everything about a resource, and it is granted constantly because it reliably makes the blockage go away.

KEY **Entra ID roles vs Azure RBAC roles — two separate systems, easy to conflate.**

	ENTRA ID ROLES	AZURE RBAC ROLES
Govern	The identity plane, users, groups, app registrations, directory settings	The resource management plane — what can be done to Azure resources
Examples	Global Administrator, User Administrator, Application Administrator	Owner, Contributor, Reader, and every service-specific role
Assignments	Separate assignments, separate scopes, separate places in the portal. A Global Administrator has no rights over Azure resources by default.	

TRAP **The elevation path defeats the usual assumption.** A Global Administrator can elevate to gain access-management rights over Azure resources at **root scope**. It is deliberate, documented and **auditable**: the action appears in the directory audit log. So the mitigation is to **alert on it**, not to

assume it cannot happen. If somebody elevates at root and nobody notices, that is a monitoring gap.

Resource locks: CanNotDelete and ReadOnly. They protect the *resource*, not the data inside it, and they sit underneath both mechanisms as a backstop.

TRAP **ReadOnly blocks operations that look like reads but are writes underneath:** listing storage account keys is the classic example. Test before applying broadly.

KEY **The stack, be able to draw it.** RBAC decides what a principal may do. PIM decides whether that assignment is standing or has to be activated.

Conditional Access decides under what circumstances the principal can authenticate at all.

→ Limit what an administrator can do = **RBAC**. → Stop them holding it permanently = **PIM**. → Require a compliant device before they can use it = **Conditional Access**.

Regulatory compliance initiatives group policy definitions and map each to specific controls, so a framework becomes assignable and measurable. **TRAP** The mapping covers only what is **technically assessable**. A standard also contains obligations about process, evidence, training and governance that no policy can evaluate, so a high score is a strong signal and **not a certification**.

DAY TWO | THE DATA PLANE AND THE PATH TO IT

2.1 Security for Azure Storage Accounts

PLANES · SAS · ENCRYPTION

A default storage account has three things open: a public endpoint · account keys with full scope · on older accounts, anonymous blob access. **Three different controls close them, and closing one does not close the others.** Before agreeing a finding has been fixed, ask which of the three it refers to.

KEY **The storage firewall covers the data plane only.** Management-plane access stays available regardless. So somebody with **Contributor** is effectively a data reader unless you have disabled account key access. **TRAP** **Reading the account keys is a management-plane operation**, even though what comes back unlocks all the data, the firewall does not stop you reading the keys.

KEY **Shared access signatures, the delegation model is the hardest part to reverse.**

TYPE	HOW IT WORKS	REVOCATION
Ad-hoc SAS	Permissions and times baked into the URL; the service holds no record of it	TRAP Cannot be withdrawn except by rotating the account key , which stops every other client at the same instant
Service SAS bound to a stored access policy	Points at a policy identifier; terms are read from the policy when the request arrives	Edit or delete the policy, takes effect on the next request, in about 30 seconds
User delegation SAS	Signed with Entra credentials	Revocable, and cannot exceed the access of whoever created it

Stored access policy: defined on the container, holding a name, a permission set, and start and expiry times. **Maximum five per container.** **TRAP** The unit of revocation is the **policy, not the individual client**: everyone sharing a policy is withdrawn together. Wanting a sixth policy means the requirement has outgrown signatures; move the caller to a managed identity and a role assignment.

Encryption at rest needs no decision. AES-256, on by default, covers everything written, **cannot be turned off**. It protects the **physical media**: a drive leaving a datacentre, a decommissioned disk. **TRAP** It does nothing about a request arriving at the API with valid credentials, because the service decrypts

automatically for authorised requests. Somebody with a stolen account key is entirely unaffected.

Key ownership is the actual decision. With **customer-managed keys** the key lives in your Key Vault or Managed HSM. Prerequisites are specific and get tested: the **vault needs soft delete and purge protection**, and the account's managed identity needs **wrap, unwrap and get** on the key.

- **Two key layers.** The *data encryption key* encrypts your blobs and is service-managed. The *key encryption key* wraps it, and that is the one you own. So CMK does not mean you supply the key that encrypts the data, it means the service's own key is locked in a box you control. That is why rotation is instant and cheap, and why losing your key is unrecoverable rather than inconvenient.
- **What you buy is a revocation path:** remove access to the key and the data becomes unreadable without anything being deleted. **TRAP** The same revocation happens by accident: a deleted key, an expired role assignment, a vault firewall change. Purge protection is a prerequisite precisely because the accidental case is more common than the deliberate one.
- **Dependency chain:** storage account → managed identity → role assignment in the vault → vault firewall. Four links, possibly three teams, and a break in any one takes the data offline.
- Use the **version-less key identifier** so the account follows key rotation automatically.

Two more for recognition. **Infrastructure encryption** adds a second layer underneath the first and can **only be selected at account creation**. **Encryption scopes** apply a different key to a specific container or blob.

Transport: Azure Blob Storage stopped supporting TLS 1.0 and 1.1 on **3 February 2026**; 1.2 is the minimum. Set **Minimum TLS version** explicitly so the requirement is visible in configuration.

Defender for Storage is the detection layer and **stays off until somebody enables it**. It asks whether authorised activity is normal, the only question left once an attacker holds a valid credential.

Everything lives in four blades: Networking · Access keys · Access control (IAM) · Data protection.

KEY Two authentication models, and the difference is *where the credential is validated*.

	SQL AUTHENTICATION	MICROSOFT ENTRA AUTHENTICATION
Validated	Username and password hash in the master database, checked by the database engine	Client requests an access token from Entra for the SQL resource, then presents it
Entra involved?	No Entra sign-in occurs at any point	Yes, at token issuance
Consequence	TRAP MFA, Conditional Access, sign-in risk and device compliance have nothing to evaluate	Those controls apply, because they run at token issuance rather than at the database

The migration **completes only when Entra-only authentication is enabled**. Token lifetime is roughly one hour. **TRAP** That means **revocation is not instant**: an existing connection continues until the current token expires.

Four Entra principal types can hold an identity: user · group · managed identity · service principal. Groups are the practical unit for people, granted roles once, after which access is controlled entirely by group membership, with no database change and no credential distribution. Managed identities are right for applications.

Interactive connection option: *Active Directory universal with MFA*. Application connection string keyword: **Authentication=Active Directory Default**.

The firewall has two rule layers.

- **Server-level rules** apply to every database on the logical server, are stored in **master**, and can be set in the portal or with `sp_set_firewall_rule`. Limit: 256.
- **Database-level rules** apply to a single database, can **only be created in T-SQL** with `sp_set_database_firewall_rule`, and are stored in that database — **TRAP** so they **do not appear in the portal**.
- Rules are **additive**: a database-level rule grants access the server-level rules do not, rather than restricting anything. Changes take up to **5 minutes** to propagate, so an immediate failed test is not evidence the rule is wrong.

KEY **TRAP** "Allow Azure services and resources to access this server" creates a firewall rule with a start and end address of **0.0.0.0**. In Azure SQL that pair is a *special value*, not a literal address, it admits connections from resources in **any Azure subscription and any tenant**, not only yours. **It is not a scoping control and the name suggests otherwise**. Replace it with virtual network rules (which need the `Microsoft.Sql` service endpoint on those subnets), specific IP rules, or a private endpoint.

Connection policy has three values: Default · Proxy · **Redirect**. **TRAP** Redirect requires the client to reach ports **11000-11999** in addition to 1433, a common outbound-firewall failure.

Visibility has three components. **Auditing** captures logins, failures and statements. **Log Analytics as the destination** is what makes Sentinel detection and cross-source correlation possible. **Defender for Databases** adds behavioural detection and a **weekly vulnerability assessment**.

Assessing an unfamiliar server: four blades, Microsoft Entra ID (authentication model), Networking (firewall), Auditing (is anything recorded), Defender for Cloud (plan) — then two queries, `sys.sql_logins` and `sys.database_principals`.

2.3 Security for Azure Networking

A **network security group** is a rule list attached to a **subnet** or a **network interface**. Rules match on direction, address, port and protocol, are evaluated in **priority order until the first match**, and are **stateful**: return traffic is allowed automatically. Default rules deny inbound from outside, allow outbound to the internet, and allow traffic within the virtual network.

An **application security group** lets rules refer to a named group of network interfaces rather than to addresses.

Azure Firewall adds filtering by fully qualified domain name, threat-intelligence-based filtering, and inheritable central policy. It is deployed in a **hub** virtual network, and **route tables** on the spoke subnets direct traffic to it.

Firewall Premium adds two capabilities: **IDPS**: intrusion detection and prevention, comparing traffic against signatures and alerting or blocking on a match; and **TLS inspection**: terminating the encrypted session, examining the contents and re-encrypting. TLS inspection requires an **intermediate certificate authority certificate held in Key Vault**.

KEY Service endpoint vs private endpoint, the wording the exam uses consistently.

	SERVICE ENDPOINT	PRIVATE ENDPOINT
What it is	A setting on a subnet , for a particular service	A network interface with a private IP inside your subnet (built on Azure Private Link)
Public endpoint	Remains . The service keeps its public IP and public name	Can be switched off entirely
The exam sentence	Restricts who may use the public endpoint , which continues to exist	Provides a private address , and allows the public endpoint to be removed
Granularity	Gives the subnet access to that service across the region	Links to one named resource and one sub-resource : blob, file, queue and table each need their own
Reach	Traffic travels Microsoft's network instead of the public internet	Reachable from peered virtual networks and from on-premises over VPN or ExpressRoute
DNS	Nothing to configure	TRAP Needs a linked private DNS zone : the usual point of failure
Cost	Free	Charged for the endpoint and the data through it

Microsoft Entra Private Access grants users access to defined **application segments** through an **outbound-only connector**, with Conditional Access evaluated **per session**.

Network Watcher gives you two tools worth naming: **IP flow verify** tests a single packet against the rules; **effective security rules** shows everything that applies to a network interface.

3.1 AI Data Risk and Exposure with Purview DSPM

KEY The Copilot access model — frequently described wrongly, and examined. Copilot operates within the permissions of the user who invoked it. It searches and summarises content that user can already open. It holds no permissions of its own and it bypasses nothing.

So Copilot grants no new access. What it changes is the cost of using access that already existed. Before, reaching a document meant knowing it existed and where it was stored; content a user was entitled to open but would never find was effectively out of reach. A question in natural language returns it, summarised. **TRAP** A question implying Copilot circumvents permissions is describing something that does not happen.

TRAP Nothing fails. The assistant works correctly, users get useful answers, and no control reports an error, so this exposure is found only by looking for it. A Copilot deployment should trigger a posture review, not a policy review.

How the exposure builds. Permission sprawl in SharePoint and Teams, organisation-wide sharing links and broad site-level permissions, usually set to resolve an immediate request. It accumulates rather than staying static because sharing links persist until somebody removes them and permission inheritance applies a site's permissions to content created in it later. Every Team is backed by a SharePoint site, so a team-level permission is a site permission.

Consequence worth knowing: reducing a site permission reduces exposure for search, sharing, and any future tool, the fix is not Copilot-specific and does not have to be repeated for the next assistant.

DSPM reports; it does not enforce. It combines three inputs into each finding: data sensitivity (does it match a sensitive information type, is a label applied) · sharing posture (how broadly, through which mechanism) · AI accessibility (is it reachable by Copilot for the users who hold access). **KEY** The third input is what distinguishes DSPM from a general data discovery tool, the output is not a list of sensitive files but a list of sensitive files a particular population can actually get to.

Findings are grouped under security objectives: defined goals such as preventing oversharing of sensitive data. DSPM works from classification and activity signals Purview already collects; it does not scan for the first time when you open it.

KEY Data risk assessments. Under DSPM → Discover. Purview runs one automatically each week against the 100 SharePoint sites with the highest usage. You can also create assessments against sites you nominate, which is

how you cover an executive site or a legal repository that matters but would never appear in a usage-ranked list.

A signal is the combination: content that is sensitive, broadly shared and unlabelled. Any one of those alone is normal.

Three remediation paths, chosen by cause. Labelling: content appropriately shared but unprotected. Access review: individuals holding access they no longer need. Reducing sharing scope: a site-level setting too broad for what the site now holds. **TRAP** Identify the cause first: applying a label to content shared with the whole organisation protects the file without changing who can see it.

Ownership split. The security engineer interprets, prioritises and documents. The content or site owner corrects permissions, they hold the permissions and know which access is legitimate. The compliance team applies or refines labelling policy, which is tenant-level and centralised because a label applied inconsistently provides weak protection.

Correcting permissions changes who can reach the content. Applying a label attaches protection that travels with the content, so it still applies if the file is moved, downloaded or shared onward. Many findings need both.

Before escalating, confirm four things: the data source · the sensitivity context (**TRAP** detection matches patterns, so a string shaped like a payment card number is reported as one regardless of what it represents) · the sharing scope · whether the population holding access would plausibly invoke Copilot. Then produce five: a risk statement, the business impact, the recommended fix, the accountable owner, and the verification checkpoint.

KEY The boundary most likely to be tested: DSPM identifies and prioritises; Information Protection enforces.

→ A requirement to discover and rank exposure = DSPM. → A requirement to prevent an action or protect a file = Information Protection (sensitivity labels and DLP). Within that: a label attaches protection to the content; a DLP policy blocks a specified action such as sharing externally.

Keeping the four Purview constructs apart — ask what each produces. DSPM produces findings. Sensitivity labels produce protection attached to content. DLP produces blocked actions. Access review produces removed permissions.

Two remediation capabilities worth naming. SharePoint Advanced Management provides sharing reports across sites and bulk actions. The tenant-level default sharing link setting governs every new share from that point forward, the highest-leverage action available, because it applies across the tenant without touching existing content.

3.2 AI Agent Identity and Access Security in Entra

An agent decides its own steps and authenticates constantly, so it needs an identity. Most controls you already run apply to it unchanged. What changes is that nobody is present to answer a prompt: every control assuming a person becomes unavailable.

KEY Identity types, establish the type first, because the policy options follow from it.

TYPE	REPRESENTS	CONDITIONAL ACCESS
Managed identity	An Azure resource authenticating to Azure services. Azure creates and manages the credential, nothing stored, nothing to rotate	TRAP Not covered. A scope boundary, not a configuration gap you can work around
Workload identity	An application. In Entra this means a service principal or a managed identity	Covered for single-tenant service principals registered in your own tenant: risk and location conditions
Entra Agent ID	An AI agent. Object ID and app ID are the same value	Targetable, with assignment options the other types do not have

Relationship: a managed identity is a workload identity; not every workload identity is a managed identity. → A VM reaching Key Vault = managed identity.

→ Applying CA to an application = workload identity. → Governing an AI agent = Agent ID.

An agent often uses more than one at once: the agent has an Agent ID, while the compute it runs on may use a managed identity to reach Azure resources. Separate identities, separate jobs, governed separately.

KEY The dual-identity model, the structural point of the module. One logical agent can map to two directory objects.

- Agent identity: service-principal-style, always present. Used for workload token flows: API calls and token requests.
- Agent user account: user-style object in the tenant, marked as belonging to an AI agent. Exists only when the agent needs to reach systems that authenticate users: mailboxes, Teams and calendars, because those services expect a user.
- Different IDs (separate objects, not two views of one). Relationship is always one to one.
- **TRAP** Conditional Access treats them as separate principal types. A policy targeting agent identities cannot target agent user accounts, and vice versa. Two objects usually need two policies: configuring one and assuming the agent is covered leaves the other unprotected.

Which object is in play? Mailbox, Teams message or calendar → the agent user account. API call or token request → the agent identity.

TRAP The agent user account is a **user object** carrying an attribute marking it as an agent, so anything that enumerates users returns it — existing user-scoped policies, reports, licence counts and scripts all already include them.

KEY The all-users MFA trap, the most common failure in agent policy design. A baseline policy requires MFA for all users. Agent user accounts are user objects, so the assignment includes them. The agent cannot complete an interactive challenge, so the sign-in fails. **Nothing is misconfigured**: the policy is working exactly as written and being applied to a principal that cannot behave like a person.

The fix has two halves and both matter. Keep the strong baseline intact for human users, then create dedicated, narrowly scoped handling for agent user accounts, rolled out in stages. **TRAP** A broad exclusion with nothing to replace it leaves those accounts covered by **no policy at all**: worse than the starting position.

The remaining levers, since interactive controls are unavailable: **location conditions, named networks, sign-in risk from ID Protection, and session controls**. Microsoft publishes recommended policies for autonomous agents, start there rather than adapting a policy written for people.

The same assumption breaks other policies too: **terms of use acceptance, password change requirements, and device compliance** (an agent has no device to be compliant).

CA targeting for agents: all agent identities · all agent users (preview) · individual agents. **Custom security attributes** are the mechanism that scales — tag agents with your own classification and target the attribute. Without them you are limited to all agents, individual object IDs, or grouping by **blueprint** (the template the agent was built from, which groups by how it was made rather than what it does).

Validate in report-only mode first. **TRAP** This matters more for agents than for people: a blocked *user* raises a ticket in minutes; a blocked *agent* fails silently, and the first sign is a business process that stopped producing output hours or days later. Give it enough time to cover the agent's full cycle of work.

KEY Workload identity CA, the boundary, precisely. **Supported**: single-tenant service principals in your own tenant. **Requires Workload Identities Premium**: a separate licence from Entra ID P1 or P2, so a tenant holding P2 does not automatically have it. **Not supported**: managed identities · Microsoft and third-party SaaS applications · multitenant applications.

TRAP The group-assignment silent failure. Service principals can be added to groups, but a **CA policy assigned to a group is not enforced for a service principal in that group**. It looks correct in the portal: the policy saves, the group contains the principal, and nothing is enforced.

Continuous access evaluation re-checks tokens when conditions change rather than waiting for expiry. It applies to workload identities in supported cases; it **does not apply to managed identities**.

What a compromised agent identity can do in one hour, four categories. Read (the agent's data access becomes the attacker's immediately) · **Send** (a message

from an internal agent carries organisational trust, so recipients apply less scrutiny) · **Call** (API operations at automation speed under a valid identity, matching the agent's normal pattern) · **Persist**.

KEY The first three abuse what the agent is allowed to do. **Persist expands what the attacker can do next**. If the agent holds identity-plane rights, the attacker can create accounts or grant access, and **those additions survive revocation of the original credential**. So sort every agent's permissions into two groups: **data permissions set the immediate impact; identity-plane permissions determine whether revoking one credential actually contains anything**.

The permission to know by name: `AgentIdUser.ReadWrite.IdentityParentedBy` — creates agent-parented user accounts within the agent's lineage. Governance rule has four parts: **IAM ownership** (the identity team decides, not the team building the agent) · **PIM-eligible activation of Privileged Role Administrator** · **documented business need** · **recurring review**.

Review test: ask what a permission lets the holder *create or grant*, not what it lets them read. Anything that can create a principal, assign a role or add a credential belongs in the second group.

TRAP Detection has to come from behaviour, not authentication failures. An attacker using a valid agent credential produces sign-ins that look correct because they *are* correct. Rules built on failed sign-ins, impossible travel or unfamiliar locations assume a person, an agent has no usual location and no working hours. What remains useful is **volume, timing, and the pattern of resources touched**.

Blast radius analysis (Defender XDR) maps what an identity can reach: inspect reachable assets → rank abuse potential by business impact and ease of exploitation → contain high-risk routes → harden the baseline. **KEY** **Run it before anything happens**. Steps one and two take time, and ranking is a conversation with the business, doing both in advance means an incident starts at step three. It looks like an incident response tool and is most valuable as a preventive one.

Agent 365, in the **Microsoft 365 admin centre** (**TRAP** not in Entra), is the inventory and control surface: **agent inventory** · **owners** · **lifecycle state** · **management posture**. The fourth turns coverage into something reportable. Agents can be created by people outside the identity team, so identities appear in the tenant without the identity team being involved.

Least privilege is a lifecycle, not a configuration task. Scope minimum access from a documented function · **review regularly** (configure reviews so that **no decision results in removal**: a review where inaction preserves access cannot reduce anything) · **control credentials** (prefer certificates or federated credentials over client secrets; an app registration can hold several secrets at once and old ones stay valid until deleted) · **re-validate on change**: a new connector, data source or owner should trigger a scope review. The fourth is the one most often skipped and it belongs in the process for *modifying* agents, not in a separate security review.

3.3 Microsoft Foundry and AI Gateway Security

A model endpoint is an API. Left unprotected it accepts anonymous requests, has no consumption ceiling, and inspects nothing.

KEY Three risk categories.

- **Prompt injection**: crafted input attempts to override the model's instructions. The system prompt and the user input **both arrive as text**, which is what makes it possible.
- **Data exfiltration**: prompts attempt to extract what is in the model's **context**: its system instructions, any documents retrieved to ground the answer, and earlier turns of the conversation. **TRAP** Conversation memory is context too, so a long session accumulates reachable material.
- **Denial of wallet**: unbounded request volume and token consumption drive cost up. The target is **the bill, not availability**, which is why it is named differently from denial of service. **TRAP** It produces **no error**, because every request is served correctly, the billing view is often where it is discovered. The protection is a **cap, not an alert**.

KEY Prompt injection arrives two ways, and the difference decides where you can defend.

TWO-LAYER MODEL · PROMPT INJECTION · DEFENDER FOR AI

	DIRECT INJECTION	INDIRECT INJECTION
Where	In the user's own prompt	In content the model retrieves: a document, a web page, an email
Visible in the request?	Yes — anything inspecting the request can examine it	TRAP No. The user's prompt is clean; the malicious content enters after the request is accepted
Caught by	Gateway inspection or content filtering	Only the model-side guardrails, which see everything in context at generation time

The model has no reliable way to distinguish instructions in retrieved content from its own system prompt, because both are text arriving in the same channel, a property of how these systems work rather than a defect to be patched. **Beyond filtering**: treat retrieved content as untrusted input, and limit what the application places in context to what the current question requires (a design decision, raised at design review).

KEY The two-layer model, the rest of the module is built on it.

	LAYER 1 GATEWAY (AZURE API MANAGEMENT)	LAYER 2 FOUNDRY GUARDRAILS AND CONTENT SAFETY
Handles	Caller authentication · rate and token limits · policy enforcement · centralised logging	Prompt filtering · output filtering · jailbreak checks · controls on sensitive output
Sees	Requests: who is calling, how often, how much they consume	Content: the prompt and the generated response
Answers	<i>May this caller make this request, and how much may they consume?</i>	<i>Is this content acceptable?</i>
Blind to	Whether a well-formed request from an authenticated caller is trying to manipulate the model	Who sent the request, and how many times

Complementary, not redundant, neither is a subset of the other. The gateway runs **first**, so unauthenticated and over-limit requests are rejected **before they reach the model and before any tokens are consumed**. That ordering also explains the split: cost is best stopped before work is done; content can only be judged once there is content to judge.
→ Scenario describing **unauthorised access or runaway cost** = **gateway**. → Scenario describing **harmful output or manipulation attempts** = **guardrails**.

Gateway policies — use policy intent language, not XML syntax.

POLICY	WHAT IT DOES
Authentication	Subscription keys, or Microsoft Entra authentication : the stronger option, because it brings the identity controls from earlier modules to bear
llm-token-limit	Enforces a token-per-minute quota , applied per client or per subscription . TRAP A quota shared across all callers together does not stop one caller consuming everything
llm-emit-token-metric	Emits token consumption to Azure Monitor with custom dimensions. This is what makes a limit tunable rather than guessed
Backend circuit breaker	Stops sending traffic to a backend that is erroring or slowing, rather than piling requests onto it. Resilience control with a security use
llm-semantic-cache-*	Stores and reuses responses for prompts close enough in meaning. Reduces cost and load, a partial mitigation for consumption abuse. Needs an external cache, usually Azure Managed Redis

3.4 AI Security Monitoring with Defender for Cloud

The **Data and AI security dashboard** is a scoped view inside Defender for Cloud, aggregating three things: **AI workload protection status** (what is covered) · **active findings** (what is risky now) · **recommendations** (what should happen next).

KEY TRAP Establish scope before reading any number. A posture dashboard reports on resources it has coverage for. **A resource with no Defender plan enabled does not appear as a problem, it appears as nothing at all.** So an empty dashboard can mean everything is healthy, or that nothing is being monitored, and those look identical until you check coverage.

Read in a fixed order: coverage → active risk → hardening work. Coverage first because it qualifies everything else; then active risk because it is time-sensitive; then hardening because it is planned rather than urgent.

TRAP It is a **snapshot refreshed on an assessment cycle**, not real time. It is not the place to verify a configuration change you made five minutes ago. It is a presentation layer over the plans you have enabled — **enabling a plan is what creates the data**.

KEY Findings vs recommendations, the distinction the module rests on.

Sequence that works: emit the metric → observe normal consumption → set the limit above the observed peak. A limit set from a guess produces either no protection or an outage.

Foundry guardrails. Content is evaluated against categories, hate, violence, self-harm, sexual, each with a **severity threshold you set**, so this is a configuration decision rather than a switch. **Jailbreak detection is a separate capability from category filtering:** it looks for attempts to manipulate the system prompt, and in Azure AI Content Safety it is called **Prompt Shields**.

Output filtering matters more than it first appears: an entirely innocuous prompt can still produce a response that should not leave, when the model was grounded on data the requester should not see. Only output inspection catches that.

TRAP Guardrails are configured per model deployment. Two deployments of the same model can carry different settings, and a **new deployment starts from the default rather than inheriting** what you configured elsewhere. The gap between deploying a model and configuring its filters is where unfiltered endpoints come from.

TRAP Two things filters cannot do: recognise something outside the defined categories, and judge **whether the requester should see a particular piece of information**: they have no view of who is asking. That is why access control at the data layer still matters, which connects back to the Purview module.

Defender for AI services, the detection layer. Enable at Defender for Cloud → Environment settings → subscription → Defender plans. It works with **Prompt Shields** and Microsoft threat intelligence. Alert categories to know by name: **jailbreak · data leakage · data poisoning · credential theft**. It also produces posture recommendations, not only alerts.

KEY The division: **Prompt Shields blocks the attempt at the content layer; Defender for AI services raises the alert so somebody knows it was made.** Without the second, blocked attempts are invisible and repeated probing looks like nothing at all.

Suspicious prompt evidence includes portions of the prompt and response in the alert, with sensitive data redacted automatically. It is optional and worth enabling, but settle the **privacy question** first, because prompt content may include material users consider personal even after redaction.

Two supplemental recognition points. **Azure AI Content Safety** also exists as a **standalone service with its own API**: needed when an architecture calls a model API directly rather than going through Foundry, in which case you invoke it yourself as a separate call. And **TRAP naming:** Azure AI Studio → Azure AI Foundry → **Microsoft Foundry**. All three names appear in documentation, so check the date on any guidance in this area.

DATA AND AI SECURITY DASHBOARD

	FINDING	RECOMMENDATION
Is	Detected risk, a detected event or an active risk signal	A control or posture gap, a configuration not meeting a baseline
Response	Investigation. Triage, validate context, possibly contain	Planned implementation. Assigned owner, due date, tracked to remediation
Timescale	Starts when it appears, interrupts other work	Scheduled — competes with other planned work
Goes to	Whoever responds to incidents	Whoever owns the resource
Reported as	Risk narrative, what happened and what it means	Implementation and closure narrative — what will change and when

The test: does the item describe **something that happened**, or **something that is missing**? Something that happened is a finding; something missing is a recommendation.

Worked pair, same resource, same day: repeated jailbreak attempts against a model endpoint is a **finding**: triaged this morning. The same endpoint having no rate limit configured is a **recommendation**: into the backlog with an owner and a date. **TRAP** Recommendations vastly outnumber findings in most environments; that is normal, not alarming.

KEY Severity sets the queue order. Business context sets the actual priority. High means immediate triage, medium means near-term planned remediation,

low is posture hygiene that should still be tracked to closure. Then refine within each band using four factors: **asset criticality** · **data sensitivity** · **blast radius** · **exploitability**.

Why severity alone is not enough: it is assigned by the product based on the finding type. The product does not know what the resource does, what it holds, what it can reach, or how exposed it is, all four come from you. Two of them you already produced earlier: **data sensitivity** from Purview classification and **blast radius** from the agent identity analysis.

Record why an item was raised or lowered relative to its severity, and be consistent. Otherwise the queue stops being defensible and becomes a matter of who asked most recently.

→ A question about **AI workload posture specifically** = the **Data and AI security dashboard**. → A question about **overall cloud posture or secure score** = the **unified Defender for Cloud view**. Both draw on the same underlying data; the difference is filtering and framing, not a different product.

DAY FOUR | WORKLOAD PROTECTION, POSTURE AND OPERATIONS

4.1 Security for Servers and Virtual Machines

DEFENDER FOR SERVERS · ARC · SCANNING

KEY Plan boundaries, the most-tested line in this module.

	DEFENDER FOR SERVERS – PLAN 1	DEFENDER FOR SERVERS – PLAN 2
Provides	Endpoint detection and response, through Defender for Endpoint	Everything in Plan 1, plus Just-in-Time access · agentless scanning · file integrity monitoring · configuration assessment

→ A question stating a requirement for **Just-in-Time** or **agentless scanning** and asking which plan satisfies it is testing that line. Those two are the clearest Plan 2 markers.

Just-in-Time access closes management ports by default and opens them for a requested period, by **writing and then withdrawing a temporary rule in the network security group**. Plan 2.

Azure Arc registers servers outside Azure as Azure resources through the **Connected Machine agent**, which is what allows Azure security services to reach them. → A question mentioning **on-premises servers, AWS instances, or any non-Azure machine** and asking how to bring Azure security tooling to bear is asking you to name **Arc**.

KEY The two scanning methods are complementary, not alternatives. The agent observes running behaviour **continuously**. **Agentless** analyses a disk

snapshot from outside the machine: no agent, no load, and describes the machine as it was at the last scan.

Findings split two ways, usually to different owners. **Vulnerabilities** are fixed by **patching**. **Recommendations** are fixed by **configuration**.

Managed disks are encrypted at rest by default. The decision is whether the key is **platform-managed** or held in your Key Vault through a **disk encryption set**.

Exam cues for the recognition topics:

→ Connect to a VM **without exposing a public IP address** = **Azure Bastion**.
→ **Boot integrity** = **Trusted Launch**.
→ Verify settings **inside the operating system** against a standard = **Machine Configuration**.
→ Add **EDR to Azure virtual machines** = **through Defender for Servers**, which provisions Defender for Endpoint for them – **not** a separate Defender for Endpoint deployment.

TRAP **Defender for Servers is a plan within Defender for Cloud, not a separate product.** Defender for Cloud also covers storage, databases and containers through their own plans, so a question naming Defender for Cloud broadly may not be about servers at all.

4.2 Security for Application Platform Services

CONTAINERS · WAF · APP SERVICE · API MANAGEMENT

Container risk sits at three points in the lifecycle: **image vulnerabilities** exist before deployment · **runtime threats** exist during execution · **lateral movement** is what follows a single compromise.

Defender for Containers provides **agentless vulnerability assessment** across registry images, running containers and nodes, with **daily rescans** and exploitability information. **Runtime threat protection** uses the **Defender sensor on the nodes** and maps detections to **MITRE ATT&CK**.

Registry security is upstream of the cluster. Scanning matters only if the result **blocks a deployment**. Least-privilege roles limit who can push; private connectivity limits who can reach the registry at all.

KEY TRAP **Kubernetes network policy behaves the opposite way to a network security group.** A pod with **no policy** allows everything. A pod selected by a policy allows **only what the policy permits**: so **selecting the pod is what creates the denial**.

Web application firewall. Run **Detection mode first, Prevention after tuning**. Rules contribute to an **anomaly score**, and a total of **5 or higher blocks the request** in Prevention mode, which is why tuning is required rather than optional. A single **Critical** match scores 5 and blocks on its own; a **Warning** match scores 3 and does not.

Rule sets. The current recommendation is **Default Rule Set (DRS) 2.2**, based on **OWASP Core Rule Set 3.3.4**. **TRAP** DRS is the Core Rule Set **plus additional**

rules Microsoft maintains: a superset rather than a rebranding, which is why the two version numbers differ. Use the latest supported set unless a compatibility requirement forces a pin; pinning is a legitimate decision, but upgrading means repeating the Detection-mode tuning, so allocate time for it.

App Service and Function Apps share three controls: **platform authentication that application code cannot bypass** · **network restrictions** · **managed identity for outbound calls**.

API Management gateway policy maps to four threats: authentication for unauthenticated use · **rate limits and quotas** for flooding · **IP filters** for untrusted networks · **logging** so the other three can be tuned. Use policy *intent* language rather than memorising XML.

Architecture cues:

→ Requirement for **specific cluster configuration or node control** = **AKS**.
→ Requirement to **run containers without managing infrastructure** = **Container Apps**.
→ A **single container with no orchestration, short-lived or batch** = **Container Instances**.
→ **Isolated hosting in your own virtual network**, usually for regulatory reasons = **App Service Environment**.

KEY The two tiers, know which capability sits where.

FOUNDATIONAL CSPM (FREE)	DEFENDER CSPM (PAID)
Asset discovery · security assessment · recommendations · secure score · Microsoft Cloud Security Benchmark. Enabled by default on every subscription	Attack path analysis · cloud security explorer · governance rules · agentless scanning · data-aware security posture · regulatory compliance beyond the default benchmark

Worth checking before assuming an environment is unassessed: the foundational data usually already exists and nobody has looked at it.

Secure score — three properties. It reflects **control completion** (a control counts as complete when all its recommendations are satisfied for the resources in scope) · it is **weighted by impact**, so closing one high-weight control moves it more than several low-weight ones · it is evaluated on a **recurring cycle** rather than continuously, so recommendation details can refresh faster than the rolled-up controls.

- **TRAP** **Relative to scope.** Comparing scores across differently sized environments is not meaningful.
- **TRAP** **It does not fall when an incident occurs.** It measures configuration against a standard, an environment can be perfectly configured and still be compromised. A high score is not a statement about safety.
- **TRAP** It has a **natural ceiling below 100** for most organisations, because some recommendations are legitimately not applicable or accepted as risk. **Report the trend, not the absolute figure:** a target set on a number with a legitimate ceiling produces pressure to dismiss recommendations rather than fix them.
- **TRAP** **Preview recommendations** are assessed and shown but **excluded from the score**, so acting on them does not move the number.

Prioritise by risk level and attack path context, not raw count. Raw count is the least useful number on the dashboard. An **attack path** is a chain of individually authorised steps that together allow an attacker to reach something valuable. **Breaking any single link stops the path**, so the question is which link is cheapest to break, and a finding on a realistic path outranks a same-severity finding that nothing can reach. Attack path analysis is **paid tier**.

Recommendations vs alerts: the same test as module 3.4: *something missing* vs *something that happened*. Alerts decay in value (the activity has finished, evidence ages out); recommendations do not. Alerts arrive unpredictably and need somebody on call; recommendations accumulate steadily and need scheduled time.

Regulatory compliance. **TRAP** The figure is calculated across the **assessable controls only**, so it describes **technical compliance rather than compliance with the standard**. Assign standards deliberately, overlapping frameworks multiply findings without multiplying the underlying problems, and most map back to the same handful of recommendations. Check the **assessment date** before quoting a figure.

KEY **Secret scanning — frame this correctly or the whole topic gets misread.** It operates on the **control plane**: it looks at development and configuration surfaces, code repositories, VM disks, infrastructure-as-code templates, pipeline variables, container images, for credentials that have escaped from where they belong. **It does not read Key Vault contents, and architecturally it cannot.**

Remediation sequence: find the exposure → identify the consumers → move the secret to Key Vault → update the consumers to reference it → **then** rotate.

TRAP Rotating before the consumers are updated breaks them. **Exception:** if the credential has been in a **public** repository, rotate immediately — third-party credential scanning is automated and continuous, so exposure time is measured in minutes.

TRAP **Terraform state stores resolved values**, so a template that reads a secret correctly can still write it in plaintext to state. The template looks clean; the exposure is in the artifact the deployment produces.

Storing a secret in Key Vault is necessary and not sufficient, the vault still needs the access model, network restrictions and deletion protections from Module 1.2.

Governance rules assign owners and due dates to findings (paid tier). Keep the criteria simple at first, and **agree due dates with the teams receiving them**: a date nobody agreed to produces an overdue report that describes the process rather than the teams.

Multicloud is delivered through **connectors** for AWS and Google Cloud. Recommendations are **equivalent in intent, cloud-specific in wording** (a storage exposure recommendation in AWS refers to S3), which is what lets a single secure score span all three. The connector needs permissions granted in the other cloud's own identity model, so setting one up is a cross-team task.

Shift-left means moving security checks earlier in the development process, so problems are found before deployment rather than after.

4.4 Microsoft Sentinel, Data Collection and Configuration

KEY **Sentinel runs on a Log Analytics workspace.** Log Analytics stores; Sentinel interprets. Sentinel holds no separate copy of anything, it reads the workspace. Three consequences follow, and they come up repeatedly:

- Anything already writing into that workspace is available with no connector: SQL auditing sent to Log Analytics, for example.
- Retention is a Log Analytics setting, not a Sentinel one.
- Correlation only works within one workspace. Data split across two cannot be joined in a single query without extra configuration, so **workspace design is a security decision**. Splitting data to control cost removes the main capability you deployed a SIEM for.

Retention and cost: 90 days free with Sentinel onboarded, extendable to **two years**; beyond that, lower-cost long-term tiers exist for compliance retention but are **not queryable in the normal way**: reaching that data needs a search job or a restore. Ingestion can be bought **per gigabyte** or in **commitment tiers** reserving a daily volume at a lower unit price.

Connector kinds. **Microsoft native:** service-to-service, simplest: grant permission, select what to ingest, the platform handles transport. **Standards-based:** Syslog, CEF (a structured variant that arrives already parsed into columns) and API paths. These usually need a **forwarder**: a Linux machine running an agent that receives events from devices and passes them to the workspace.

Data collection rules (DCR) define what is collected and where it is sent; the **Azure Monitor Agent** reads the rule and applies it, so one agent can serve several requirements. **TRAP** A filter in a DCR can **silently exclude everything**

while the agent is healthy and the connector reads connected. The Azure Monitor Agent **replaced the retired Log Analytics agent**.

KEY **TRAP** **Connector status reports on configuration, not on data.**

Connected does not mean flowing. The badge can show connected because permissions were granted and setup completed, while no events arrive, the source may be idle, a filter may exclude everything, the forwarder may not be receiving, or permissions may have changed after setup.

Verify with two things beyond the badge: the **last received timestamp**, and a **direct query against the target table**. The query is the definitive check; everything else is an indicator. Know which table the connector writes to before you start, and expect ingestion latency of several minutes.

For ongoing operation: Sentinel writes health information for connectors, automation rules and playbooks into a dedicated health table — build a scheduled rule that alerts when a connector stops producing data. Otherwise silent ingestion failure is found during an investigation, when the evidence is missing.

The Defender XDR connector is normally first: one integration brings endpoints, identities, email, applications and cloud apps into the workspace for correlation with everything else. **TRAP** Synchronisation **starts at the point of connection**; alerts created before the connector was enabled do not appear retrospectively.

Analytics rule types. **Scheduled:** runs a query on a defined interval; the general-purpose type covering most custom detections. **Near-real-time (NRT):** runs at a **fixed short interval** with restrictions on the query, trading flexibility for speed. **Fusion:** machine learning correlating **low-fidelity signals** across

sources into one high-confidence incident; **enabled by default**, produces relatively few incidents by design, so treat a Fusion incident as high priority.

KEY Automation rules are response, not detection. An analytics rule detects and creates the incident; an automation rule responds to incident lifecycle events. Sequence: analytics rule detects → incident created → automation rule responds. Triggers: incident created · incident updated · alert-to-incident flow. Their value is consistency, not speed, the same owner, severity and tags every time, including at three in the morning.

- Rules have an **order** property; a later rule can overwrite what an earlier one set, so order is part of the logic.
- Rules can carry an **expiry date**: useful for temporary routing without leaving a rule nobody remembers.
- TRAP** A rule that runs a playbook needs **Sentinel to hold permission on the resource group containing that playbook**. Without it the rule **saves successfully and fails at run time**: a permission problem, not a logic problem.

4.5 Microsoft Security Copilot Configuration

SCUS · ROLES · PLUGINS · AGENTS

Two places it appears. The **standalone portal**: a dedicated workspace for prompting across products, suited to questions that cross sources; sessions persist, and **prompt books** save a sequence of prompts that runs as a unit (the main way teams get consistent output). The **embedded experience**: inside Defender XDR, Sentinel, Intune and others, in context alongside what the analyst is already looking at.

KEY TRAP Both draw on the same central configuration: the same roles, plugin settings and data boundaries. There is **no separate embedded configuration to secure**, and restricting a plugin restricts it everywhere Copilot appears. Embedded experiences appear only **after capacity is provisioned** and setup is complete.

KEY Security Compute Units (SCUs) are the capacity powering everything – standalone sessions, embedded use, and **agent workloads that run with nobody present**, all from the same pool.

MICROSOFT 365 E5 / E7	EVERYONE ELSE
400 SCUs per month for every 1,000 paid user licences, up to 10,000 per month, provisioned automatically. Scales for fewer than 1,000 too (400 licences → 160 SCUs)	Provision manually. You select a number of units and can add overage units for spikes beyond the provisioned amount

Capacity is **region-scoped**: the region determines where processing happens, so it is a data-residency decision made at provisioning. **TRAP** Provisioned capacity is **charged for being provisioned, not only for being used**. A usage dashboard shows units consumed and **which plugins were engaged**: useful for governance as well as cost.

KEY The role model, and the point most likely to be misunderstood. Owner manages capacity association, settings and governance controls. **Contributor** runs sessions and operational workflows.

Neither is a Microsoft Entra ID role. They function like access groups controlling access to the **Security Copilot platform capabilities only**, and by themselves they **grant no access to security data at all**. Copilot operates within each user's existing permissions in the underlying products, **it creates no new access**, exactly like Microsoft 365 Copilot. Somebody with no access to Defender data does not gain it by being made a contributor.

TRAP The platform **enforces a minimum of two owners** at all times, so an owner cannot be removed if it would leave fewer than two. Two reviewed owners is the target, not one. Note that whoever provisions capacity becomes an owner by that action.

Owner settings — treat as a governance control, not an onboarding formality. Capacity management and SCU association · whether **Microsoft may capture**

Playbooks are Azure Logic Apps workflows with a Sentinel trigger, receiving the incident context as a payload. So anything Logic Apps can do becomes a response action. **KEY** A playbook **runs under its own identity**, usually a managed identity, which needs permission to do whatever the playbook does, **so a playbook is a privileged principal and should be treated as one**. Playbooks can be run manually on an incident for testing, and run history shows the input and output of every step.

Content Hub publishes **solutions** packaging connectors, analytics rules, workbooks and playbooks together. → A question asking the **fastest way to onboard a common source** points at the Content Hub solution rather than building each component. **TRAP** Analytics rules arrive as **templates**: installing a solution is **not** a detection running; somebody still has to create the rule and set its scope and threshold.

data to improve Copilot (a data-sharing decision your privacy or legal function will have a view on) · **audit logging into Microsoft Purview** · **file upload governance** (uploaded files become part of the context, so this is a data path that does not come through plugins).

KEY TRAP Without audit logging you cannot answer who asked Copilot **what**: a question that will eventually be asked, particularly after an incident involving an analyst account. Turning it off does not delete past records, but it creates a gap that cannot be filled retrospectively.

Plugins control what Copilot can reach. Microsoft plugins provide product-specific context. **Non-Microsoft** plugins connect to third-party products that publish an integration. **Custom** plugins can be restricted to owners only, a custom plugin is code reaching a data source or performing an action Microsoft did not build, so it should go through whatever review you apply to code touching production data.

KEY TRAP Enabling a plugin does not grant data access. It authorises Copilot to use that data path **on behalf of a user who already has access**. A plugin for a product the analyst cannot read returns nothing for them. So **plugins define the maximum surface; the user's own permissions define what they actually see**.

TRAP A plugin restriction takes effect **everywhere at once and immediately**: including for an analyst mid-investigation. **Plugin changes are production changes**.

Four-step decision model: identify the use case (state it in writing) → **validate permissions** in the source product for the users who will use it → **enable narrowly**, smallest audience first → **review periodically**, because plugins accumulate exactly as permissions do. Decision criteria: **need, data sensitivity, owner accountability**.

Agents automate tasks. **Apply blast radius thinking**: the same framing as the agent identity module. Three properties make them different from interactive sessions: they **run without a person present**, they **consume capacity continuously**, and they **act rather than only answer**. An agent operates with permissions that come from how it was set up, so the ownership question applies exactly.

Review question: for every agent running, who owns it, what can it reach, and would you be comfortable with that person performing the same action manually at three in the morning without asking anybody? If not, it is scoped too broadly.

Responsible operation: use **citations** (they tell you which record the answer came from, so checking one is fast, the cheapest defence against a confident wrong answer) · **verify output**, treating an answer as a starting point rather than a conclusion · keep **plugin scope controlled**. → A question about safe AI operations practice wants answers describing **verification and scoping**, not restriction of the tool itself.

Cross-module quick reference

The distinctions that get confused because they were taught in different modules. These are the highest-yield pages on the sheet.

NON-HUMAN IDENTITY TYPES, AND WHAT CONDITIONAL ACCESS REACHES

TYPE	REPRESENTS	CONDITIONAL ACCESS	EXAM CUE
Managed identity	An Azure resource; Azure manages the credential	TRAP Not covered at all	VM reaching Key Vault, Storage or SQL
Workload identity (service principal)	An application	Single-tenant only, in your own tenant. Needs Workload Identities Premium	Applying CA to an application
Entra Agent ID	An AI agent; object ID = app ID	Targetable — all agents, individual, or by custom security attribute	Governing an AI agent
Agent user account	The same agent's user-style object	Separate principal type, needs its own policy	Agent sending mail or posting in Teams

TRAP Two silent failures to memorise: a CA policy assigned to a group is **not enforced** for a service principal in that group. And **continuous access evaluation** does not apply to managed identities.

CONTROL PLANE AND DATA PLANE

MODULE	THE CONTROL	WHAT IT DOES NOT COVER
Storage	The storage firewall covers the data plane	Management-plane access, so Contributor is effectively a data reader unless account key access is disabled. Reading the keys is a management-plane operation
Key Vault	RBAC data-plane roles govern secret retrieval	Where the vault can be reached from, that is the firewall, and deletion, which is soft delete and purge protection
Azure SQL	Entra authentication brings CA and MFA to bear at token issuance	Anything under SQL authentication, because no Entra sign-in occurs
Defender CSPM	Secret scanning reads control-plane surfaces: code, disks, IaC, pipeline variables	Key Vault contents: it cannot read them, architecturally
Governance	Azure RBAC governs the resource management plane	The identity plane, that is Entra ID roles , a separate system with separate scopes

IDENTIFY, ENFORCE, DETECT: WHERE EVERY PRODUCT SITS

IDENTIFY / PRIORITISE	ENFORCE / PREVENT	DETECT / REPORT
Purview DSPM: finds and ranks data exposure Foundational CSPM: secure score, recommendations Blast radius analysis: what an identity can reach Attack path analysis: reachable chains	Information Protection: sensitivity labels and DLP Azure Policy: Deny, DeployIfNotExists RBAC / PIM / Conditional Access AI gateway (API Management), auth, rate and token limits Foundry guardrails / Prompt Shields: content and jailbreak	Defender for Key Vault / Storage / Databases / Servers / Containers Defender for AI services: jailbreak, data leakage, data poisoning, credential theft Microsoft Sentinel: cross-source correlation Auditing and sign-in logs

→ Discover and rank exposure = DSPM. → Prevent an action or protect a file = Information Protection. → Know that a blocked attempt was made = the Defender detection layer. **KEY** Prompt Shields **blocks**; Defender for AI services **alerts**.

FINDINGS, RECOMMENDATIONS AND ALERTS

THE TEST	ANSWER
Something that happened	Finding / alert. Investigation now. Goes to incident responders. Decays in value — evidence ages out
Something that is missing	Recommendation. Planned remediation with an owner and a date. Goes to the resource owner. Does not decay

Same resource, same day: *repeated jailbreak attempts on an endpoint* = finding. *That endpoint has no rate limit* = recommendation. **TRAP** Recommendations vastly outnumber findings, that is normal.

TIERS, PLANS AND LICENCES

BOUNDARY	LOWER / FREE	HIGHER / PAID
Defender for Servers	Plan 1: EDR via Defender for Endpoint	Plan 2: adds Just-in-Time , agentless scanning , file integrity monitoring, configuration assessment
Defender for Cloud posture	Foundational CSPM: assessment, recommendations, secure score, MCSB. On by default	Defender CSPM: attack path analysis , cloud security explorer, governance rules, agentless scanning, data-aware posture, regulatory compliance
Entra ID Protection	Without P2, premium detections surface only as a generic "additional risk detected"	Entra ID P2: full detail on risk detections
Conditional Access for service principals	Entra ID P1 / P2 does not cover it	TRAP Workload Identities Premium: a separate licence
Security Copilot capacity	Manual provisioning, with optional overage units	M365 E5 / E7: 400 SCUs per month per 1,000 paid licences, up to 10,000
Azure Firewall	Standard: FQDN filtering, threat intelligence, central policy	Premium: IDPS and TLS inspection (needs an intermediate CA certificate in Key Vault)

NAMING TRAPS: SETTINGS THAT SUGGEST THE WRONG THING

NAME	WHAT IT ACTUALLY DOES
"Allow Azure services and resources to access this server" (Azure SQL)	TRAP Creates a rule with start and end address 0.0.0.0 : a special value admitting any Azure resource in any subscription and any tenant . Not a scoping control
Resource lock, ReadOnly	TRAP Blocks operations that <i>look</i> like reads but are writes underneath — listing storage account keys is the classic case
"Allow trusted Microsoft services" (Key Vault)	TRAP Admits services such as Backup and Event Grid regardless of the firewall . A deliberate trust decision, not a default
Connector status "Connected" (Sentinel)	TRAP Reports on configuration, not data . Verify with the last received timestamp and a query against the target table
Encryption at rest (Storage)	TRAP Protects the physical media . A request arriving with valid credentials is entirely unaffected
Content Hub solution installed	TRAP Analytics rules arrive as templates . A solution installed is not a detection running
Security Copilot "Owner" and "Contributor"	TRAP Not Entra ID roles . They grant no access to security data : Copilot runs within the user's existing permissions
Kubernetes network policy	TRAP Opposite to an NSG. No policy = allow everything ; selecting a pod is what creates the denial
Preview recommendations (secure score)	TRAP Assessed and displayed but excluded from the score

NUMBERS TO MEMORISE

NUMBER	WHAT IT BELONGS TO
7 to 90 days	Key Vault soft delete retention window, fixed at creation
5 per container	Maximum stored access policies on a storage container
~30 seconds	Time for a stored access policy change to take effect
AES-256	Storage encryption at rest, on by default, cannot be disabled
3 February 2026	Azure Blob Storage stopped supporting TLS 1.0 and 1.1; minimum is 1.2
256	Azure SQL server-level firewall rule limit
Up to 5 minutes	Azure SQL firewall rule propagation
11000–11999	Ports needed in addition to 1433 under the Redirect connection policy
~1 hour	Entra access token lifetime for Azure SQL, so revocation is not instant
~1 day	Managed identity access token lifetime, cached at the metadata layer
Weekly, top 100 sites	Purview data risk assessment : automatic, against the SharePoint sites with the highest usage
Weekly	Defender for Databases vulnerability assessment
Daily	Defender for Containers registry image rescans
5	WAF anomaly score that blocks in Prevention mode. Critical = 5 alone; Warning = 3
DRS 2.2 / CRS 3.3.4	Current Azure WAF Default Rule Set, and the OWASP Core Rule Set it is based on
90 days free, up to 2 years	Sentinel data retention with Sentinel onboarded
400 per 1,000, max 10,000	Security Copilot SCUs per month for M365 E5 / E7 paid user licences
Two	Minimum Security Copilot owners the platform enforces
Three	Entra ID Protection risk tiers — low, medium, high
Four	Prioritisation factors: asset criticality, data sensitivity, blast radius, exploitability

SCENARIO CUES: READ THE REQUIREMENT, NAME THE COMPONENT

IF THE SCENARIO DESCRIBES...	THE ANSWER IS...
Limiting what an administrator can do	Azure RBAC
Stopping an administrator holding it permanently	PIM : eligible assignment with activation
Requiring a compliant device before they can authenticate	Conditional Access
A VM authenticating to Key Vault, Storage or SQL	Managed identity : and CA does not reach it
Protecting a platform service so the public endpoint can be removed	Private endpoint (a service endpoint leaves it in place)
Connecting to a VM without a public IP	Azure Bastion
Verifying settings inside the guest OS against a standard	Machine Configuration
Boot integrity for a VM	Trusted Launch
Bringing Azure security tooling to on-premises or AWS machines	Azure Arc (Connected Machine agent)
Adding EDR to Azure virtual machines	Defender for Servers , which provisions Defender for Endpoint
A requirement for Just-in-Time or agentless scanning	Defender for Servers — Plan 2
Discovering and ranking where sensitive data is overexposed	Purview DSPM
Preventing a file being shared externally	Information Protection : sensitivity labels and DLP

Copilot returning content a user should not have seen	Existing over-permission: Copilot bypasses nothing
An agent that must send mail or post in Teams	The agent user account , needing its own CA policy
Agent sign-ins failing after an all-users MFA baseline	Agent user accounts are user objects — keep the baseline, add narrow agent handling
Unauthorised access or runaway cost on a model endpoint	The AI gateway: API Management
Harmful output or manipulation attempts	Foundry guardrails / Prompt Shields
A model returning information it was told not to disclose, after processing an external document	Indirect prompt injection
Calling a model API directly , outside Foundry	Azure AI Content Safety invoked as a separate call
Correlating third-party logs with Microsoft signal	Microsoft Sentinel (Defender XDR covers Microsoft products)
The fastest way to onboard a common log source	Content Hub solution
Attack path analysis or cloud security explorer	Defender CSPM: the paid tier
AI workload posture specifically	Data and AI security dashboard
Whether overall cloud posture is improving	Unified Defender for Cloud view and secure score trend
Cluster or node control for containers	AKS (versus Container Apps for managed, Container Instances for a single container)
Isolated hosting in your own virtual network, usually regulatory	App Service Environment
What unit powers Security Copilot usage	Security Compute Unit (SCU)

The night before

If you read nothing else, read this page. These are the items most likely to be answered wrongly by somebody who attended the whole course.

TEN CLAIMS THAT SOUND RIGHT AND ARE WRONG

THE PLAUSIBLE WRONG ANSWER	WHAT IS ACTUALLY TRUE
Copilot can reach content the user cannot	It operates within the invoking user's permissions . It creates no access and bypasses nothing, it removes the effort of using access that already existed
A Global Administrator controls Azure resources	No rights over Azure resources by default . There is a documented, auditable elevation to root scope, alert on it
The storage firewall protects the account	Data plane only . Contributor is effectively a data reader unless account key access is disabled
Conditional Access can protect a managed identity	It cannot : a scope boundary, not a gap. Use access reviews, role scope and resource permissions instead
Put the service principal in a group and target the group	Not enforced . The policy saves, the group contains it, nothing happens
One agent, one policy	Two directory objects : agent identity and agent user account — treated as separate principal types. Usually two policies
Exclude agent users from the MFA baseline and you are done	That leaves them covered by nothing . Pair the exclusion with a replacement policy deployed at the same time
The gateway will catch prompt injection	Only the direct kind. Indirect injection enters through retrieved content, after the request was accepted
Guardrails configured once cover the model	Configured per deployment . A new deployment starts from the default and inherits nothing
The connector shows connected, so data is flowing	Status reports configuration . Verify with the last received timestamp and a query against the target table

THE FIVE SENTENCES TO BE ABLE TO SAY VERBATIM

- **Service endpoint vs private endpoint**. A service endpoint restricts *who may use the public endpoint*, which continues to exist. A private endpoint provides a *private address* and allows the public endpoint to be removed.
- **DSPM vs Information Protection**. DSPM identifies and prioritises risk. Information Protection enforces the controls that reduce it.
- **Findings vs recommendations**. A finding describes something that happened and drives investigation. A recommendation describes something that is missing and drives planned remediation.
- **The two-layer AI model**. The gateway answers whether this caller may make this request and how much they may consume. The guardrails answer whether this content is acceptable.
- **Automation vs analytics rules**. Analytics rules detect and create incidents. Automation rules respond to incident lifecycle events and do no detection of their own.

THREE HABITS FOR WORKING THE QUESTIONS

- **Name the plane first**. Identity, management or data. A surprising number of questions resolve the moment you decide which one the requirement sits in.
- **Ask what the option produces**. DSPM produces findings. Labels produce protection attached to content. DLP produces blocked actions. Access review produces removed permissions. The requirement usually names one of those outputs.
- **Watch for the tier**. If two options are both technically correct, one of them is usually the paid tier or a higher plan, and the question is testing the boundary, not the capability.

Last thing. Almost nothing in this course required a control you did not already know. Conditional Access, access reviews, least privilege, firewalls, encryption and inventory all appeared again for AI workloads. What changed was the **principal** they are applied to, and the removal of every control that assumes somebody is present to respond. If a question about an AI workload looks unfamiliar, ask what the equivalent control would be for a person or a server, the answer is usually the same shape.